

MAPEO NORMATIVO DETALLADO

Correspondencia entre Preguntas de la Encuesta y Requisitos Normativos Aplicables

Kit de Encuesta CVSS 4.0 • España 2025-2026

"La normativa sin métrica es una declaración de intenciones. La métrica sin normativa es un dato sin contexto. Juntas, son una política de ciberseguridad."

TABLA MAESTRA DE MAPEO

ID Pregunt a	Enuncia do resumid o	ENS (RD 311/202 2)	NIS2 (Dir. 2022/25 55)	DORA (Reg. 2022/25 54)	CRA (Reg. 2024/28 47)	ISO 27001:2 022	NIST CSF 2.0	CVSS 4.0 Ref.
P1.7	¿Sujeto al ENS?	Art. 2 Ámbito de aplicació n	—	—	—	—	—	—
P1.8	Categorí a ENS del sistema más crítico	Anexo I: Categorías BAJO/M EDIO/AL TO	—	—	—	A.8.1 Clasifica ción	ID.AM	Environ mental CR/IR/A R
P2.1- P2.3	Conocim iento y versión CVSS usada	CCN- STIC 817 § Gestión de vulnerab ilidades	Art. 21.2.e Gestión de vulnerab ilidades	Art. 9 Gestión de TIC	Art. 13 Actualiz ación de producto s	A.8.8 Gestión técnica de vuln.	ID.RA-1	CVSS Spec. § Nomencl atura
P2.4	Razón para no migrar a v4	CCN- STIC 817	Art. 21.2.e	Art. 9.2	Art. 13.6	A.8.8	ID.RA-1	CVSS SIG adoption gap
P2.5	Respons able de asignar CVSS	CCN- STIC 817 § 4 Roles	Art. 21.1 Medidas de gestión	Art. 5.2 Goberna nza TIC	Art. 13.1 Goberna nza	A.5.2 Roles y responsa bilidades	GV.RR	CVSS CIG § Who sets metrics
P2.6	Frecuenc ia revisión scores CVSS	Anexo II op.exp.4 Gestión vuln.	Art. 21.2.e	Art. 9.3 Program as de prueba	Art. 13.3 Supervis ión	A.8.8	RS.MA-3	CVSS CIG § Lifecycle
P2.7	Uso del Base Score como puntuaci ón definitiv a	CCN- STIC 817	Art. 21.4 Proporci onalidad	Art. 9.4	Art. 13.4	A.8.8	ID.RA	CVSS CIG § Beyond Base Score

P3.1	Conocimiento cambios métricas Base v4	CCN-STIC 817 § 5 Metodología	Art. 21.2	—	—	A.8.8	ID.RA-1	CVSS v4 Spec § Base Metrics
P3.2	Diferenciación impacto VC/VA vs SC/SA	op.exp.4 ENS (análisis impacto)	Art. 21.2.b Análisis de riesgo	Art. 9.2 BIA	Art. 13.3	A.8.15 / A.8.16	ID.RA-5	CVSS v4 § SC/SI/SA metrics
P3.3	Fiabilidad CVSS Base en entorno propio	op.exp.4 ENS	Art. 21.4 Proporcionalidad de riesgo	Art. 9	Art. 13.4	A.8.8	ID.RA	CVSS CIG § Enrichment
P3.4	Metodología específica para OT/ICS	op.exp.4 ENS + CNPIC sectores	Art. 21.2 (OT implícito)	Art. 9 (sistemas digitales)	Art. 13 (productos con elem. digitales)	A.8.8 + A.8.21	PR.IR-4	CVSS v4 § SC/SI/SA + Safety
P3.5	Disfunciones observadas en métricas Base	CCN-STIC 817 § Observaciones	—	—	—	—	—	CVSS limitations (literatura)
P4.1	Uso sistemático de métricas Threat	op.exp.4 ENS	Art. 21.2.e + Art. 23 Notificación	Art. 9.2 TLPT	Art. 13.3	A.5.7 Threat intelligence	ID.RA-1	CVSS v4 § Exploit Maturity
P4.2	Fuentes de threat intelligence para E/Threat	op.exp.4 ENS	Art. 21.2.e + Art. 29 Intercambio info	Art. 9.2 TLPT	Art. 13.3	A.5.7	ID.RA-2	CVSS CIG § Threat group
P4.3	Reducción volumen con métricas Threat	op.exp.4 ENS	Art. 21.4	Art. 9.2	Art. 13	A.8.8	RS.AN-3	CVSS SIG empírica l data

P4.4	Integración EUVD (ENISA 2025)	CCN-CERT coordinación ENISA	Art. 27 EUVD obligatorio para CNAs	Art. 9.2	Art. 12 EUVD en CRA	—	ID.RA-2	EUVD launch April 2025
P4.5	Impacto CRA en disponibilidad datos Threat	—	Art. 23 NIS2	—	Art. 13, 14, 15 CRA vulns.	—	ID.RA	CRA Art. 13 obligations
P4.6	Integración plataforma vuln. + threat intel	op.exp.4 ENS	Art. 21	Art. 9	Art. 13	A.8.8 + A.5.7	ID.RA + PR.DS	CVSS v4 lifecycle
P5.1	Uso de métricas Ambiental	op.exp.4 ENS (análisis riesgo)	Art. 21.1 Análisis riesgo	Art. 6 Marco riesgo TIC	Art. 13.2	A.8.8 + A.5.9 Inventario	ID.RA + PR.PS	CVSS v4 \$ Environmental group
P5.2	Inventario activos (CMDB) actualizado	mp.si.1 ENS: Inventario activos	Art. 21.2.a Gestión activos	Art. 9.2 Registro activos TIC	Art. 13.1	A.8.1 Inventario	ID.AM-1	CVSS CIG \$ Prerequisites
P5.3	Establecimiento CR/IR/AR	Categorización ENS ALTO/MEDIO/BAJO	Art. 21.4 Proporcionalidad	Art. 5 Gobernanza TIC	Art. 13.2 Evaluación riesgo	A.8.1 + A.5.12 Clasificación	ID.RA + GV.RM	CVSS v4 \$ CR/IR/AR
P5.4	Controles de seguridad en métricas Modified	Anexo II ENS controles	Art. 21.2.c Seguridad sistema	Art. 9 Medidas resiliencia	Art. 13.3 Medidas seguridad	A.8 Controls (múltiples)	PR.PS + PR.IR	CVSS v4 Modified Base Metrics
P5.5	Proceso respuesta vulnerabilidades ENS Alto	Anexo I ENS + CCN-STIC 817	Art. 23 Notificación incidentes	Art. 10 Notificación ICT	Art. 14 Notificación 24h	A.8.8	RS.MA	CVSS CIG \$ Response SLAs

P5.6	Madurez métricas Ambiental (escala)	op.exp.4 ENS	Art. 21 Medidas gestión riesgo	Art. 9 Gestión riesgo TIC	Art. 13	A.8.8	ID.RA + PR.PS	CVSS v4 Consumer Guide
P6.1	Conocimiento métricas Suplemental	CCN-STIC (OT/ICS)	Art. 21.2 (sectores OT/safety)	—	Art. 13.3	A.8.8	PR.IR	CVSS v4 § Suplemental
P6.2	Uso métrica Safety en OT/médica	CNPIC + Ley 8/2011 IC	Art. 21.2 (infraestructuras críticas)	—	Art. 13.3	A.8.21 Seguridad red y OT	PR.IR-4	CVSS v4 § Safety metric
P6.3	Mecanismos detección vulnerabilidades wormable	op.exp.4 ENS	Art. 21.2.e	Art. 9.2	Art. 13.3	A.8.8	DE.CM	CVSS v4 § Automatability
P6.4	Importancia métricas Suplemental en decisiones	op.exp.4 ENS	Art. 21	Art. 9	Art. 13	A.8.8	RS.AN	CVSS v4 § Suplemental impact
P6.5	Escenario real de Suplemental	(abierta — evidenciación a cuali)	—	—	—	—	—	CVSS practical application
P7.1	Sujeto a NIS2	—	Art. 3 Entidades esenciales/importantes	—	—	—	GV.RM	NIS2 scope
P7.2	Integración CVSS en notificación NIS2	CCN-STIC 817 § Notificación	Art. 23 Notificación 24h/72h	—	—	A.5.26 Respuesta incidentes	RS.CO	CVSS + NIS2 integration

P7.3	Rol CVSS en DORA	—	—	Art. 9 Gestión riesgo TIC + Art. 10 Notificac ión	—	A.8.8	ID.RA	DORA technical require ments
P7.4	Conocim iento CRA en gestión vulnerab ilidades	—	—	—	Art. 13, 14, 15 CRA	—	ID.RA	CRA vulnerab ility obligatio ns
P7.5	Sistemas de scoring usados	op.exp.4 ENS	Art. 21.2.e	Art. 9	Art. 13	A.8.8	ID.RA-1	CVSS + EPSS + SSVC + KEV
P7.6	Alineaci ón con marcos normati vos (escala)	Todos ENS controle s	Art. 21 NIS2	Arts. 5– 16 DORA	Arts. 13– 15 CRA	A.8.8 + Clausula 6.1.2	GV.OC	CVSS Consum er Guide
P8.1	Herrami entas de gestión de vulnerab ilidades	op.exp.4 ENS	Art. 21.2.e	Art. 9	Art. 13.3	A.8.8	PR.PS	CVSS tooling
P8.2	Soporte nativo CVSS 4.0 en herrami entas	op.exp.4 ENS	Art. 21.2.e	Art. 9.2	Art. 13.3	A.8.8	PR.PS	CVSS v4 adoption
P8.3	Uso IA/LLM para scoring CVSS	—	Art. 21.2.e	Art. 9	Art. 13 (AI Act intersect .)	A.8.8	PR.PS	AutoCVS S / JewelCV SS 2026
P8.4	Tiempo CVE – puntuaci ón CVSS	op.exp.4 ENS (SLA vuln.)	Art. 23 NIS2 (ventana explotaci ón)	Art. 9	Art. 14 CRA (24h notif.)	A.8.8	RS.MA-3	CVSS SIG adoption gap

[illegible]

P10.2	Evolución deseada de CVSS	—	Art. 21 (perspectiva)	—	Art. 13 (perspectiva)	—	—	CVSS SIG roadmap
P10.3	Valoración Red Nacional de SOC (RNS)	CCN-CERT RNS coordinación	Art. 29 Intercambio información	—	—	A.5.6 Relaciones autoridades	RS.CO	CCN-CERT RNS >250 SOC's
P10.4	Impacto EUVD en soberanía digital	—	Art. 27 EUVD NIS2	—	Art. 12 CRA + EUVD	—	ID.RA-2	ENISA EUVD April 2025
P10.5	Propuestas para AP española	CCN / INCIBE / CNPIC	ENISA / NIS2 Art. 7 Estrategia	—	Art. 1-5 CRA	—	GV.OC	Política pública ciberseguridad
P10.6	Cambio deseado en estándar CVSS	—	—	—	—	—	—	CVSS SIG open consultation
P11.1-P11.3	IGM autopercibido y planes mejora	ENS global	NIS2 Art. 21	DORA Art. 9	CRA Art. 13	Cláusula 9.1 Evaluación	ID.RA + GV.RM	CVSS maturity benchmarks

LEYENDA DE REFERENCIAS NORMATIVAS

Esquema Nacional de Seguridad (ENS) — RD 311/2022

- Art. 2: Ámbito de aplicación
- Anexo I: Sistema de categorización (BAJO/MEDIO/ALTO)
- Anexo II: Marco de medidas de seguridad
- op.exp.4: Gestión de vulnerabilidades (explícitamente)
- mp.si.1: Inventario de activos
- org.4: Proceso de seguridad
- op.ext.1: Gestión de proveedores/terceros

NIS2 — Directiva UE 2022/2555

- Art. 3: Entidades esenciales e importantes
- Art. 20: Responsabilidad del órgano de dirección
- Art. 21: Medidas de gestión de riesgos de ciberseguridad
- Art. 21.2.e: Gestión y divulgación de vulnerabilidades
- Art. 23: Obligaciones de notificación de incidentes (24h/72h/1 mes)
- Art. 27: Base de datos de vulnerabilidades (EUVD)
- Art. 29: Intercambio de información entre entidades

DORA — Reglamento UE 2022/2554

- Art. 5: Gobernanza TIC
- Art. 9: Gestión, clasificación y notificación de incidentes TIC
- Art. 10: Notificación de incidentes TIC graves (4h inicial)
- Art. 11: Gestión del riesgo TIC de terceros
- Arts. 26–27: Pruebas de resiliencia operativa digital

Cyber Resilience Act (CRA) — Reglamento UE 2024/2847

- Art. 13: Obligaciones de los fabricantes de productos con elementos digitales
- Art. 13.1: Gobernanza de la seguridad durante el ciclo de vida
- Art. 13.3: Gestión de vulnerabilidades (desde lanzamiento)
- Art. 13.6: Política de divulgación coordinada (CVD)
- Art. 14: Notificación a ENISA de vulnerabilidades explotadas activamente (24h)
- Art. 15: Notificación de incidentes graves

ISO/IEC 27001:2022

- A.5.7: Inteligencia de amenazas
- A.5.19–A.5.22: Seguridad en relaciones con proveedores
- A.8.1: Inventario de activos de información
- A.8.7–A.8.8: Protección contra malware y gestión técnica de vulnerabilidades

NIST Cybersecurity Framework 2.0 (CSF 2.0)

- GV (Govern): Gobierno de la ciberseguridad
- ID (Identify): Identificación y gestión de riesgos
- ID.RA: Evaluación de riesgos
- ID.AM: Gestión de activos
- PR (Protect): Medidas de protección
- PR.PS: Seguridad de la plataforma
- RS (Respond): Respuesta a incidentes
- RS.MA: Gestión de respuesta

CUADRO DE MANDOS DE COBERTURA NORMATIVA

Marco Normativo	Nº preguntas que lo mapean	Cobertura (%)	Secciones de mayor densidad
ENS (RD 311/2022)	48 de 64	75%	S1, S5, S7, S9
NIS2 (Dir. 2022/2555)	42 de 64	66%	S4, S7, S9, S10
ISO 27001:2022	38 de 64	59%	S3, S4, S5, S8, S9
NIST CSF 2.0	35 de 64	55%	S2, S4, S5, S8, S9
CVSS v4.0 Spec/CIG	64 de 64	100%	Todas
CRA (Reg. 2024/2847)	28 de 64	44%	S4, S7, S8, S10
DORA (Reg. 2022/2554)	22 de 64	34%	S7, S9 (sector financiero)
CNPIC / Ley 8/2011 IC	12 de 64	19%	S3 (OT), S6 (Safety)

Kit de Encuesta CVSS 4.0 · España 2025–2026 · Mapeo Normativo
Versión 1.0 · Abril 2026